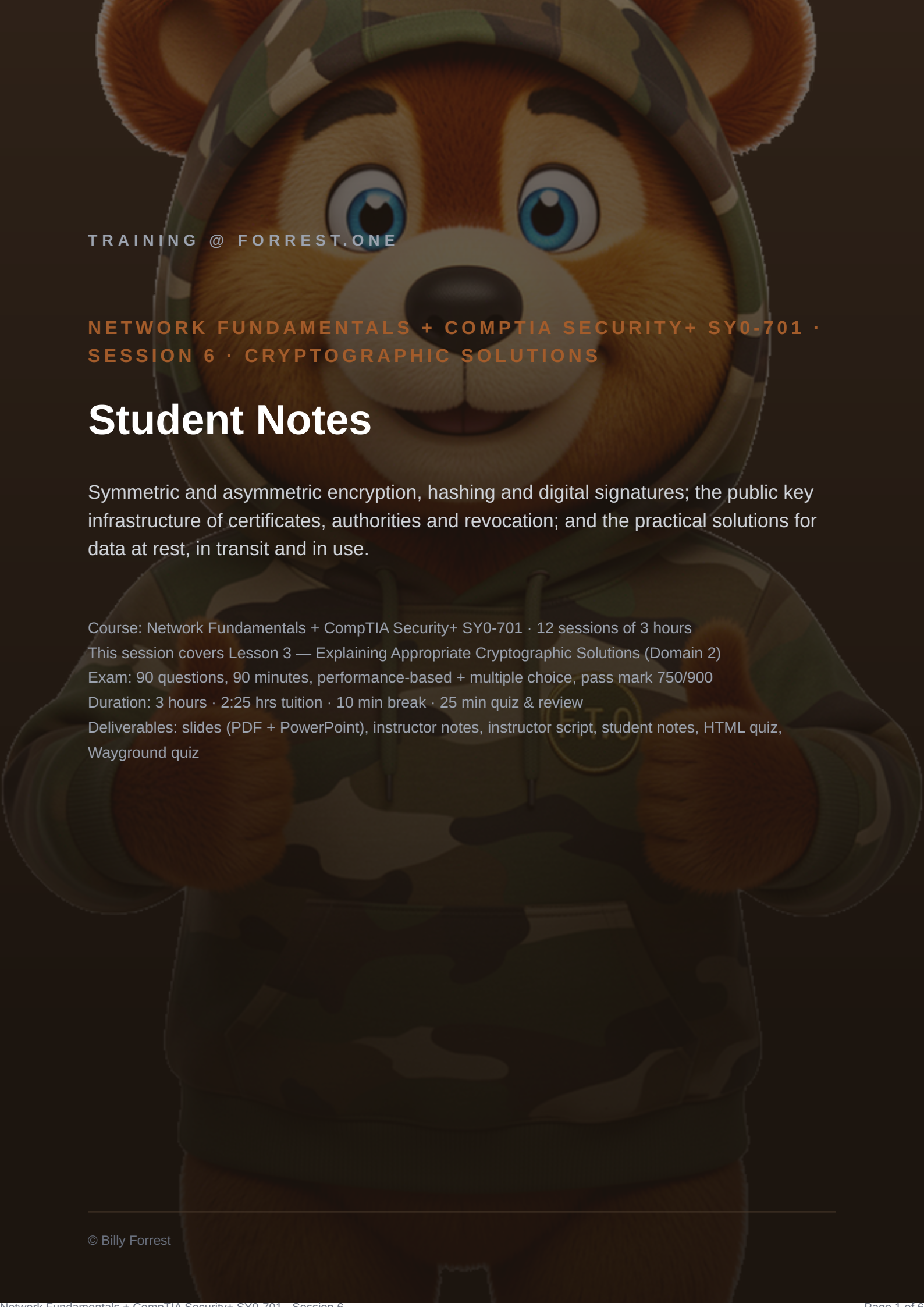




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 6 · CRYPTOGRAPHIC SOLUTIONS

Student Notes

Symmetric and asymmetric encryption, hashing and digital signatures; the public key infrastructure of certificates, authorities and revocation; and the practical solutions for data at rest, in transit and in use.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 3 — Explaining Appropriate Cryptographic Solutions (Domain 2)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Student Notes, Cryptography, PKI & Identity

Your revision guide for Session 6. Read it alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready. The session hangs on three maps: the three-job map (encrypt, hash, sign), the data-state map (at rest, in transit, in use), and the identity map (authentication proves who you are, authorisation decides what you may do).

Key terms

Term	Definition
CIA triad	Confidentiality, integrity and availability: the three jobs every control serves
Vulnerability / threat / exploit / risk	A weakness; anything that could exploit it; the method used; likelihood combined with impact
Symmetric encryption	One shared secret key encrypts and decrypts: fast, for bulk data
AES	Advanced Encryption Standard: symmetric, with key sizes of 128, 192 or 256 bits
Asymmetric encryption	Public and private key pair: public encrypts, private decrypts
RSA / ECC	Asymmetric algorithms: RSA rests on factoring difficulty; ECC uses smaller keys
Keyspace	The range of possible key values; longer keys mean larger keyspaces
Hashing	One-way, fixed-length digest with the avalanche effect: integrity, not secrecy
SHA-256 / SHA-1 / MD5	The modern standard; broken by collision attacks; broken on demand
Digital signature	Hash encrypted with the private key: integrity, authentication, non-repudiation
PKI	The infrastructure that proves the identity of a public key holder
Certificate authority (CA)	Verifies identity and issues certificates, signing each with its private key
Registration authority (RA)	Performs identity checks on behalf of the CA before issuance
X.509	The digital certificate standard
CN / SAN	Common Name (legacy FQDN) and Subject Alternative Name (modern, wildcards)
CSR	Certificate signing request: carries the public key and identity, never the private key
CRL / OCSP	Revocation list published periodically, and a real-time query about one certificate
TPM / HSM	Motherboard cryptoprocessor, and a dedicated hardware security module

Term	Definition
Key escrow	Backup of keys with a trusted third party, with M-of-N control splitting recovery
Perfect forward secrecy	Ephemeral session keys, so a later compromise cannot decrypt past traffic
Salting / key stretching	A random per-password value, and extra hashing rounds against brute force
Tokenisation / data masking	Substituting a value with a token in a vault, and fictitious data for testing
Steganography	Concealing the existence of a message, often in an image's least significant bits
Blockchain	A distributed ledger of blocks chained by hashes: tamper-evident, not tamper-proof
Documentation / version control	Policies, procedures and diagrams kept current; repository, commit, branch
Authentication / authorisation	Proving who you are, and deciding what you may do
Role-based access control	Permissions assigned to roles, and people assigned to roles
Provisioning / deprovisioning	Creating and removing identity and access across the lifecycle
The three factors	Something you know, something you have, something you are
TOTP / passwordless	A time-based one-time password, and authentication without a password at all
SSO / SAML / federation	One login for many applications; assertion exchange; trust between organisations
RADIUS / TACACS+	Network access authentication over UDP, and device administration over TCP
LDAP / LDAPS	Directory protocol on port 389, secured on 636 or upgraded with StartTLS
ACL	A list of permission entries attached to an object, read in order, first match wins
DAC / MAC / ABAC	Owner-set permissions; central policy; attribute-based with place and time

Core concepts

1 • The three jobs and the vocabulary

Confidentiality, integrity and availability are the three jobs, and every control in this session serves one of them. Encryption and access controls serve confidentiality, hashes and signatures serve integrity, and redundancy serves availability. Use the vocabulary precisely: a vulnerability is a weakness, a threat is anything that could exploit it, an exploit is the method or tool, and risk combines likelihood with impact, which is how you prioritise.

2 • Cryptographic algorithms

Symmetric: one key, fast, bulk data, distribution problem. AES is the standard, with 128, 192 or 256-bit keys, and each added bit doubles the attacker's work. Asymmetric: key pairs, which solve distribution, and are slower, so they protect keys and small payloads. RSA rests on factoring difficulty; elliptic curve cryptography reaches similar strength with smaller keys, which suits mobile and constrained devices. TLS shows both together: an asymmetric handshake exchanges a symmetric session key, then symmetric encryption carries the session.

3 • Integrity and trust

Hashing is one-way, deterministic and fixed-length, it shows the avalanche effect, and it should be collision resistant: SHA-256 or better, with SHA-1 and MD5 treated as broken. A digital signature hashes the message and encrypts that hash with the sender's private key, giving integrity, authentication and non-repudiation, but not confidentiality. Certificates bind a public key to a verified identity, issued by a CA after checks by an RA, and read in the X.509 format. Trust flows from a self-signed root through intermediates to the leaf certificate. The CSR carries the public key and never the private key; CN is legacy and SAN is modern; revocation is published through a CRL or queried live over OCSP, and it sits in the lifecycle of issuance, renewal, revocation and expiration. Key management covers the lifecycle, TPM and HSM cryptoprocessors, and escrow with M-of-N control.

4 • Applied solutions and the paper trail

Data at rest: full disk, volume or file encryption, and database encryption at table, column or cell level. Data in transit: TLS and VPN tunnels, with perfect forward secrecy so ephemeral session keys protect traffic recorded earlier. Data in use: processed in memory, the hardest state. Passwords: salting plus key stretching. Then the applications: tokenisation and data masking, code obfuscation, steganography (hiding existence, not meaning), and blockchain, where each block carries the previous block's hash so tampering is detectable. Documentation and version control close the loop, because knowing what changed, and when, is half of security.

5 • Identity and access

Authentication proves who you are; authorisation decides what you may do; a user can be authenticated and still be denied. Least privilege grants the minimum needed. Role-based access control assigns permissions to roles, and the identity lifecycle runs from provisioning through modification to deprovisioning, which is the step organisations most often forget. The three factors are something you know, something you have and something you are, and multi-factor means two or more different families. One-time passwords are time-based with a short window, phishing can relay a code, and passwordless designs use a biometric, a device key or a link. Single sign-on reduces password fatigue and centralises policy and revocation; SAML exchanges signed assertions between an identity provider and a service provider. Federation extends that trust between organisations, which widens the blast radius of a single compromise.

6 • Controlling access

RADIUS centralises authentication, authorisation and accounting over UDP, and you meet it in VPN access and wireless 802.1X. TACACS+ uses TCP, separates all three functions, and gives command-level control, which suits managing network devices. Directories such as Active Directory are built on LDAP, a hierarchy of

organisational units, groups and user objects carrying attributes, and they are optimised for reading and searching. Authentication follows bind, search, compare and result, on port 389 in the clear, on 636 with LDAPS, or upgraded with StartTLS. Access control lists are read in order, first match wins, and no match means the default, normally deny. Discretionary access lets the owner decide, mandatory access follows central policy, and attribute-based access evaluates user, resource and environmental attributes together, including geofencing and time-based restrictions.

Practical cautions

- Do not use asymmetric encryption for bulk data: symmetric is the bulk tool.
- Do not rely on encryption for integrity: hashing does that job.
- Do not treat a certificate as a safety rating: it proves key-to-identity binding only.
- Do not use MD5 or SHA-1 for anything modern: use SHA-256 or better.
- Do not store passwords without salt and stretching.
- Do not confuse CRL with OCSP: one is a published list, the other a real-time query.
- Do not confuse encryption with obfuscation or steganography: they protect different things.
- Do not count a password plus a personal identification number as multi-factor.
- Do not leave accounts active after someone leaves: deprovision on the day they go.
- Do not send directory credentials over port 389 unencrypted: use LDAPS or StartTLS.
- Do not assume one login is free of risk: it is one point of failure, so protect the session.
- Do not confuse RADIUS with TACACS+: network access versus device administration.

Self-check questions

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 6

- Job-fit is the exam skill: which algorithm, for which purpose.
- Sign with private, verify with public: memorise the direction, and remember it is not confidentiality.
- Data-state questions: at rest → disk, file or database; in transit → TLS and perfect forward secrecy; in use → memory controls.
- Know the pairs the exam loves: CN versus SAN, CRL versus OCSP, TPM versus HSM, RADIUS versus TACACS+, LDAP versus LDAPS.
- Recognise algorithms by role: AES symmetric, RSA and ECC asymmetric, SHA-256 for integrity.
- Remember that salting defeats pre-computed tables and stretching raises the cost of each guess.
- Separate identity from access: authentication proves who you are, authorisation decides what you may do.

- Count factors by family, not by credential: two things you know are still single factor.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives: the cryptography, identity and access objectives.
- NIST cryptographic standards and guidance (SP 800-series).
- The course reference chapters on public key infrastructure, encryption, hashing, blockchain, identity and access management, RADIUS, TACACS+ and LDAP.
- Your browser's certificate viewer: inspect subject alternative names and the chain of trust in the wild.